

Informe de Evaluación de Vulnerabilidades

16 de enero de 2026

Contexto empresarial: Enfocado en marketing, RGPD, datos de clientes y campañas comerciales

Descripción del sistema

El hardware del servidor es de en un procesador CPU de alto rendimiento y 128 GB de memoria RAM. Se ejecuta la última versión del sistema operativo Linux y aloja un sistema de gestión de base de datos MySQL. Está configurado con una conexión de red estable utilizando direcciones IPv4 e interactúa con otros servidores en la red corporativa. Las medidas de seguridad incluyen conexiones cifradas mediante SSL/TLS.

Alcance

El alcance de esta evaluación de vulnerabilidades se centra en los controles de acceso actuales del sistema. Se ha definido un período de análisis de tres meses, desde junio hasta agosto de 2026, con el objetivo de observar posibles riesgos de forma realista.

Para estructurar el análisis, se toma como referencia el marco en concreto de NIST SP 800-30 Rev. 1, que sirve como guía para la identificación y evaluación de riesgos en el sistema de información.

Propósito

El propósito de este análisis de vulnerabilidades es evaluar los riesgos que afectan al servidor de base de datos, que es un activo crítico que almacena y gestiona información esencial sobre clientes, campañas comerciales y datos analíticos utilizados para optimizar operaciones de marketing. Hay proteger la confidencialidad, integridad y disponibilidad de estos datos ya que hay que mantener la continuidad del servicio, cumplir con requisitos legales de protección de datos personales y preservar la reputación de la organización. Esta evaluación identifica amenazas relevantes, estima su probabilidad y gravedad, y prioriza las acciones de seguridad necesarias para reducir el riesgo global del sistema de información.

Evaluación de riesgos

Fuente de amenaza	Evento de amenaza	Probabilidad (1-3)	Gravedad (1-3)	Riesgo (P x G)
Ciberdelincuente organizado	Exfiltración masiva de datos de clientes mediante explotación de vulnerabilidades de inyección SQL o credenciales comprometidas	3	3	9
Administrador interno	Interrupción de operaciones críticas por	2	3	6

Fuente de amenaza	Evento de amenaza	Probabilidad (1-3)	Gravedad (1-3)	Riesgo (P×G)
negligente	configuración errónea de permisos o eliminación accidental de tablas de campaña			
Competidor industrial	Robo de información estratégica de analítica y campañas comerciales mediante ingeniería social o acceso no autorizado	2	2	4
Proveedor externo comprometido	Alteración o borrado de datos críticos a través de cuentas de terceros con privilegios excesivos sin supervisión adecuada	2	3	6
Malware tipo ransomware	Cifrado de archivos de base de datos MySQL que impide acceso a información comercial y paraliza operaciones de marketing	2	3	6

Escala aclaratoria: Probabilidad/Gravedad: 1=Baja, 2=Media, 3=Alta. Riesgo: 1-3=Bajo, 4-6=Medio, 7-9=Alto

Enfoque

En este análisis se han tenido en cuenta los procedimientos de almacenamiento y gestión de datos del negocio, centrándome en las amenazas más relevantes para un servidor de base de datos conectado a la red corporativa. Para identificar posibles riesgos, se han considerado varias cosas, tanto las fuentes de amenaza como los eventos más probables, teniendo en cuenta la arquitectura actual del sistema y los permisos de acceso configurados.

También se ha evaluado la gravedad de los incidentes potenciales según su impacto en el día a día del área de marketing, la posible pérdida de datos de clientes y el cumplimiento de normativas como el RGPD. Se han priorizado escenarios realistas basados en vectores de ataque habituales contra servidores MySQL expuestos, y también los errores humanos frecuentes observados en otros entornos corporativos similares.

Estrategia de remediación

Para remediar y mitigar estos riesgos, se recomendaría implementar las siguientes medidas de seguridad alineadas con el principio de defensa en profundidad:

Controles de acceso y autenticación:

- Implementación de un marco AAA robusto (Autenticación, Autorización y Auditoría) que registre y monitorice todos los accesos al servidor de base de datos.

- Aplicación del principio de menor privilegio mediante controles de acceso basados en roles (RBAC), asegurando que usuarios y aplicaciones solo tengan permisos estrictamente necesarios.
- Obligatoriedad de autenticación multifactor (MFA) para todas las cuentas administrativas y de gestión de base de datos.
- Políticas de contraseñas robustas con longitud mínima de 14 caracteres, complejidad y rotación periódica cada 90 días.

Seguridad de red y datos:

- Migración completa de SSL a TLS 1.3 para cifrado de datos en tránsito, eliminando protocolos obsoletos y vulnerables.
- Implementación de cifrado de datos en reposo para archivos de base de datos MySQL utilizando soluciones como LUKS o MySQL Enterprise Encryption.
- Configuración de listas blancas de direcciones IP (IP allow-listing) que limiten conexiones únicamente desde rangos de red corporativos autorizados, bloqueando accesos externos no controlados.
- Segmentación de red mediante VLANs que aislen el servidor de base de datos de segmentos menos seguros de la infraestructura.

Monitorización y respuesta:

- Despliegue de soluciones de monitorización de actividad de base de datos (DAM) para detectar comportamientos anómalos, consultas sospechosas y accesos no autorizados en tiempo real.
- Habilitación de registros de auditoría completos en MySQL que capturen todas las operaciones DDL, DML y cambios de configuración.
- Establecimiento de procedimientos de respuesta ante incidentes con tiempos de reacción definidos y equipos responsables.

Gestión de vulnerabilidades y continuidad:

- Programa trimestral de evaluación de vulnerabilidades y aplicación inmediata de parches críticos de seguridad para el sistema operativo Linux y MySQL.
- Implementación de copias de seguridad automatizadas diarias con almacenamiento fuera de línea (offline) y pruebas mensuales de procedimientos de recuperación.
- Revisión anual de permisos de cuentas de terceros (proveedores) con auditorías de acceso y revocación de privilegios innecesarios.